

Table of Contents

Tài liệu đặc tả nghiệp vụ — TCKT Activity Hub

PHẦN A — TÀI LIỆU NỀN: HIỆN TRẠNG HỆ THỐNG

Nguồn: mã nguồn tại `src/routes/*.js`, `src/policies/access.js`, `src/middleware/auth.js`, `src/services/*.js`, `public/app.js`, `db.sql`. Đường dẫn kèm số dòng để tra cứu nhanh.

A.1 Tổng quan hệ thống

TCKT Activity Hub là hệ thống quản lý **hoạt động (Activity)** và **công việc (Task)** nội bộ cho một tổ chức có cấu trúc **Ban điều hành** → **các Tổ/Ban (Team)** → **Thành viên (User)**. Hỗ trợ đăng nhập cục bộ và SSO qua tài khoản HUST (Microsoft, `@hust.edu.vn` / `@sis.hust.edu.vn`).

Kiến trúc: Node.js/Express (backend, `src/routes`), MySQL (schema `db.sql`), giao diện là 1 trang HTML/JS thuần (`public/app.js`, single-page, điều hướng bằng `#hash`), không có build step frontend.

A.1.1 Các thực thể nghiệp vụ chính

Thực thể	Bảng DB	Vai trò trong nghiệp vụ
Team (Tổ/Ban)	teams	Đơn vị tổ chức, có Tổ trưởng/Tổ phó
User (Người dùng)	users	Tài khoản, có vai trò hệ thống (role)
User_teams	user_teams	Quan hệ nhiều-nhiều User ↔ Team, đánh dấu ai là Tổ trưởng/Phó
Activity (Hoạt động)	activities	Sự kiện hoặc công tác được giao, có quy trình duyệt
Activity_teams	activity_teams	Các Tổ tham gia 1 hoạt động (chủ trì/hỗ trợ)
Activity_proposals	activity_proposals	Lịch sử nộp/duyet đề án hoạt động
Participant (Người tham gia)	participants	Thành viên đăng ký/được thêm vào hoạt động
Task (Công việc)	tasks	Đầu việc thuộc 1 hoạt động, giao cho 1+ người
Task_assignees	task_assignees	Người được giao 1 task (1 chính + phụ)

Thực thể	Bảng DB	Vai trò trong nghiệp vụ
Task_attachments	task_attachments	Minh chứng/tệp/link đính kèm vào task
Task_checklists	task_checklists	Việc con (checklist) trong 1 task
Update (Cập nhật)	updates	Bình luận / báo cáo tiến độ / minh chứng / ghi chú nghiệm thu trên hoạt động hoặc task
Document (Tài liệu)	documents	Văn bản/link tài liệu dùng chung theo năm & Tổ ban hành
Notification	notifications	Thông báo trong ứng dụng (+ trạng thái gửi email/push)
Weight preset	weight_presets	Thang điểm trọng số công việc dùng khi tự ghi nhận việc

A.2 Vai trò & phân quyền (RBAC)

Vai trò hệ thống (cột role bảng users), theo thứ tự quyền giảm dần:

Role	Nhóm	Mô tả
admin	Ban điều hành (Executive)	Toàn quyền hệ thống
vice_admin	Ban điều hành (Executive)	Toàn quyền hệ thống (tương đương admin trong hầu hết luồng)
leader	Leadership	Tổ trưởng — quản lý 1 hoặc nhiều Tổ mà mình đứng đầu
vice_leader	Leadership	Tổ phó — quyền tương tự Tổ trưởng trong phạm vi Tổ mình
member	Thành viên	Thành viên thường, chỉ thao tác trên việc được giao/tham gia

Vai trò **Team-level** (user_teams.is_lead / is_vice_lead) tách biệt với role hệ thống: một người có thể là Tổ trưởng của Tổ A (role hệ thống tự cập nhật thành leader) — vai trò hệ thống được đồng bộ tự động mỗi khi vai trò trong Tổ thay đổi (không set tay), trừ tài khoản đã là admin/vice_admin [teams.js:12](#), [teams.js:13](#).

A.2.1 Ma trận quyền cấp middleware

Định nghĩa tại [auth.js](#):

Middleware	Điều kiện
auth	Đã đăng nhập (có session)
admin	role ∈ {admin, vice_admin}
manager	role ∈ {admin, vice_admin, leader, vice_leader}
managerOrEventLead	manager, hoặc là Trưởng BTC (event_lead_id) / người tạo hoạt động / Tổ trưởng-phó của 1 Tổ tham gia hoạt động đó

A.2.2 Quy tắc phân quyền theo phạm vi (Policy) — [access.js](#)

Hàm	Ý nghĩa
activityScope(user)	Ban điều hành thấy tất cả hoạt động; người khác chỉ thấy hoạt động công khai hoặc hoạt động của Tổ mình tham gia
canManageTeam(user, teamId)	Ban điều hành: mọi Tổ; Leadership: chỉ Tổ mình là Tổ trưởng/phó
managedTeamIds(user)	Danh sách Tổ mà user được quản lý
canManageUser(user, targetId)	Ban điều hành: mọi tài khoản; Leadership: chỉ tài khoản member cùng Tổ mình quản lý; không được tự sửa bản thân qua route này
canManageActivity(user, activityId)	Ban điều hành: mọi hoạt động; hoặc là người tạo / Trưởng BTC / Tổ trưởng-phó của 1 Tổ tham gia
visibleActivity(user, activityId)	Theo activityScope
canReviewTask(user, task)	Ban điều hành, Tổ trưởng/phó của Tổ phụ trách task, hoặc Trưởng BTC của hoạt động — thành viên thường không được tự nghiệm thu

A.3 Xác thực & tài khoản (Authentication)

A.3.1 Đăng nhập nội bộ (local)

- POST /api/login — email + mật khẩu (bcrypt), tài khoản phải is_active=1. Trả lỗi chung “Email hoặc mật khẩu không đúng” (không tiết lộ tài khoản nào sai) [system.js:17](#).
- POST /api/logout — hủy session.
- GET /api/session — trả thông tin user hiện tại (dùng để giữ trạng thái đăng nhập khi tải lại trang).

Phiên đăng nhập lưu phía server qua `express-mysql-session` (cookie `tkct.sid`, `httpOnly`, `sameSite=lax`, bắt `secure` ở `production`, hết hạn sau 12 giờ).

A.3.2 Đăng nhập SSO Microsoft (tài khoản HUST)

- GET `/auth/microsoft` → redirect sang Microsoft OAuth (chỉ khi đã cấu hình `AZURE_CLIENT_ID/AZURE_CLIENT_SECRET`).
- GET `/auth/microsoft/callback` → xác thực state (chống CSRF), đổi code lấy token, lấy profile, **chỉ chấp nhận email đuôi `@hust.edu.vn` hoặc `@sis.hust.edu.vn`**, tự tạo tài khoản nếu chưa có (`findOrCreateHustAccount`), từ chối nếu tài khoản đã bị vô hiệu hóa.
- Sau khi đăng nhập, hệ thống phân loại tài khoản HUST thành `student` hoặc `faculty` dựa theo email `hust-identity.js`:
 - o **Faculty** (`@hust.edu.vn`): lần đầu đăng nhập phải xác nhận thông báo (modal), lưu `faculty_notice_acknowledged_at`. POST `/api/onboarding/faculty-notice`.
 - o **Student** (`@sis.hust.edu.vn`): hệ thống tự suy ra khóa (cohort) từ email, bắt buộc khai báo **lớp** ở lần đăng nhập đầu (và mỗi lần sau nếu chưa khai). POST `/api/onboarding/student-class`.

A.3.3 Hồ sơ cá nhân

- PATCH `/api/account` — tự đổi email, số điện thoại, màu avatar, mật khẩu (≥8 ký tự).

A.3.4 Quản lý tài khoản (do Manager trở lên thực hiện)

- POST `/api/users` — tạo tài khoản mới (Leadership chỉ tạo được role `member` trong Tổ mình quản lý; bắt buộc chọn ≥1 Tổ nếu là `member`; mật khẩu bắt buộc nếu `auth local`).
- POST `/api/users/bulk-import` (chỉ admin) — nhập hàng loạt danh sách thành viên (`name`, `email`, `team_ids`), tự cấp mật khẩu ngẫu nhiên + `auth_provider=microsoft` (đăng nhập bằng SSO), bỏ qua dòng trùng email/thiếu dữ liệu.
- PATCH `/api/users/:id` — sửa thông tin, đổi vai trò, đổi Tổ, đổi mật khẩu, kích hoạt/vô hiệu hóa.
- DELETE `/api/users/:id` — xóa tài khoản; nếu có dữ liệu tham chiếu (đã có hoạt động/task) thì **tự động chuyển sang vô hiệu hóa** (`is_active=0`) thay vì xóa cứng; Leadership chỉ được gỡ khỏi Tổ mình quản lý (không xóa hẳn nếu còn thuộc Tổ khác); không được tự xóa tài khoản đang đăng nhập.
- GET `/api/people` — danh sách người dùng, phạm vi theo `activityScope`-tương tự (Ban điều hành: tất cả; Leadership: người trong Tổ mình quản lý; Member: chỉ bản thân).

A.4 Quản lý Tổ/Ban (Teams)

- GET `/api/teams` — danh sách Tổ đang hoạt động (`is_active=1`), kèm số thành viên, số hoạt động đang chạy.
- POST `/api/teams` (chỉ admin) — tạo Tổ mới.
- PATCH `/api/teams/:id` (manager, phải quản lý được Tổ đó) — sửa màu; **chỉ Ban điều hành** được sửa tên/mô tả.

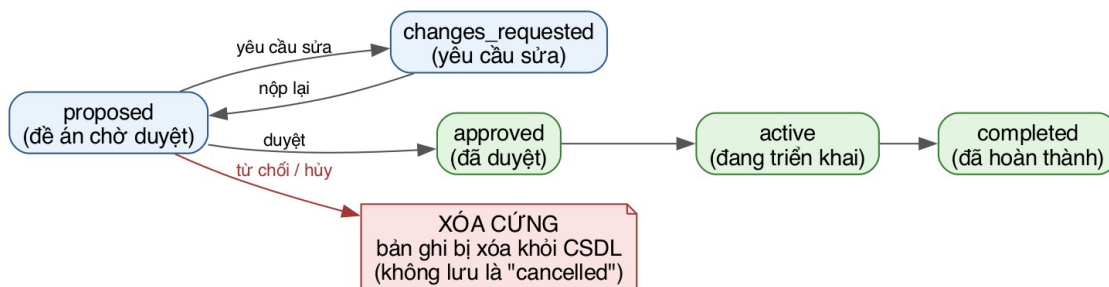
- DELETE /api/teams/:id (chỉ admin/Ban điều hành) — **không cho xóa** nếu Tổ còn hoạt động đang approved/active, hoặc còn task chưa done. Nếu xóa cứng thất bại do ràng buộc khóa ngoại khác → tự chuyển sang **vô hiệu hóa** (is_active=0) và gỡ hết thành viên khỏi Tổ. Sau khi xóa/vô hiệu hóa, vai trò hệ thống của các thành viên liên quan được tính lại.
- GET /api/teams/:id/members — danh sách thành viên hiện tại + danh sách tài khoản khả dụng để thêm.
- POST /api/teams/:id/members — thêm 1 người vào Tổ (kèm vai trò trong Tổ: member/vice_leader/leader; Leadership chỉ được thêm tài khoản member).
- PATCH /api/teams/:id/members/:userId (chỉ admin) — đổi vai trò 1 thành viên trong Tổ (member/tổ phó/tổ trưởng) → đồng bộ lại role hệ thống.
- DELETE /api/teams/:id/members/:userId — gỡ thành viên khỏi Tổ; Leadership **không được** gỡ Tổ trưởng/Tổ phó hoặc tài khoản có vai trò từ Leadership trở lên.
- GET /api/teams/:id/overview — trang tổng quan 1 Tổ: thống kê task mở/xong/trễ hạn, danh sách thành viên kèm số task, danh sách task, danh sách hoạt động liên quan.

A.5 Quản lý Hoạt động (Activity) — luồng đề án & phê duyệt

A.5.1 Thuộc tính & phân loại

- type: event (sự kiện — có các giai đoạn before/during/after) hoặc assigned (công tác được giao — chỉ có giai đoạn chung general).
- priority: low/medium/high/urgent.
- is_public: hoạt động công khai (mọi người dùng đều thấy dù không thuộc Tổ tham gia), có thể gắn ảnh minh họa công khai.
- Có 1 Tổ **chủ trì** (primary) + có thể nhiều Tổ **hỗ trợ** (supporting) qua activity_teams.
- Có thể gán **Trưởng ban tổ chức** (event_lead_id) — người này có quyền quản lý hoạt động ngang Leadership dù không phải Tổ trưởng.

A.5.2 Vòng đời trạng thái (status)



Vòng đời trạng thái hoạt động

Có một điểm dễ gây nhầm: trạng thái cancelled không phải là một trạng thái “lưu trữ” như completed. Bất kể do Ban điều hành từ chối đề án, admin đổi trạng thái thủ công, hay gọi API xóa — hệ hoạt động chuyển sang cancelled là hệ thống **xóa cứng ngay lập tức** toàn bộ dữ liệu liên quan trong 1 transaction: updates, task_attachments, task_assignees, tasks, participants, activity_teams, rồi mới xóa chính activities, kèm xóa luôn file vật lý đã đính kèm

(`hardDeleteActivity()`), [activities.js:8-32](#)). Nói cách khác, một khi đã hủy thì không còn gì để tra cứu lại — `cancelled` chỉ tồn tại trong khoảnh khắc làm điều kiện kích hoạt xóa, chứ không phải một trạng thái tồn tại lâu dài.

Ai chuyển được trạng thái nào:

Hành động	Endpoint	Ai được thực hiện	Điều kiện trạng thái hiện tại
Tạo đề án hoạt động	POST /api/activities	Manager (Ban điều hành hoặc Leadership); Leadership chỉ đề xuất được cho Tổ mình lãnh đạo	— (khởi tạo proposed)
Nộp / nộp lại đề án	POST /api/activities/:id/submit	Người quản lý được hoạt động đó (managerOrEventLead)	proposed hoặc changes_requested
Phê duyệt	POST /api/activities/:id/approve	Chỉ admin/Ban điều hành	proposed
Từ chối (→ xóa cứng)	POST /api/activities/:id/reject	Chỉ admin/Ban điều hành, bắt buộc nhập lý do	proposed
Yêu cầu sửa đổi	POST /api/activities/:id/request-changes	Chỉ admin/Ban điều hành, bắt buộc nhập lý do	proposed
Đổi trạng thái tùy ý (kể cả active/completed/cancelled)	PATCH /api/activities/:id (field status)	Chỉ Ban điều hành	canManageActivity
Xóa thủ công	DELETE /api/activities/:id	Chỉ admin	—

Mỗi lượt nộp/duyet/từ chối/yêu cầu sửa được ghi vào `activity_proposals` (lịch sử đề án) kèm người nộp, người duyệt, ghi chú phản hồi.

A.5.3 Tạo & sửa hoạt động

- Trường bắt buộc khi tạo: tiêu đề, mô tả, hạn chót (`deadline`), loại (`event/assigned`), ≥ 1 Tổ tham gia (1 Tổ là chủ trì).
- Ảnh công khai (`public_image_url`) và văn bản đề án (`proposal_document_url`) đều phải là URL `http(s)` hợp lệ — validate ở cả frontend/backend.
- Sửa hoạt động (PATCH): trường thường (tiêu đề, mô tả, hạn, ngày bắt đầu, địa điểm, người yêu cầu, mức ưu tiên, tổng kết kết quả) sửa được bởi người quản lý hoạt động; đối **Tổ tham gia** hoặc **trạng thái/Trường BTC** chỉ Ban điều hành được sửa; không được bỏ 1 Tổ ra khỏi hoạt động nếu Tổ đó đang còn task.

A.5.4 Người tham gia hoạt động (Participants)

- POST /api/activities/:id/volunteer — bất kỳ ai nhìn thấy hoạt động đều có thể **tự đăng ký tham gia** (trạng thái volunteered).
- POST /api/activities/:id/participants — người quản lý **thêm/xác nhận** thành viên vào hoạt động (trạng thái confirmed), kèm mô tả trách nhiệm; Leadership chỉ thêm được thành viên thuộc Tổ mình đang tham gia hoạt động. Gửi email thông báo cho người được thêm mới.
- Trạng thái người tham gia: volunteered (tự đăng ký) → confirmed (được xác nhận) hoặc declined (từ chối tham gia).

A.5.5 Bình luận / Cập nhật tiến độ (Updates)

- POST /api/activities/:id/updates — đăng bình luận/tiến độ/sự cố/minh chứng lên hoạt động hoặc gắn vào 1 task cụ thể; có thể **gắn thẻ (tag)** người khác (chỉ áp dụng khi kind='comment'), không được tự tag chính mình; người được tag phải nhìn thấy hoạt động đó. Sinh thông báo (in-app + email/push) cho người được tag, và cho người giao việc (assigned_by) khi có phản hồi trên task của họ.

A.5.6 Tự ghi nhận công việc trong hoạt động (Self-logged task)

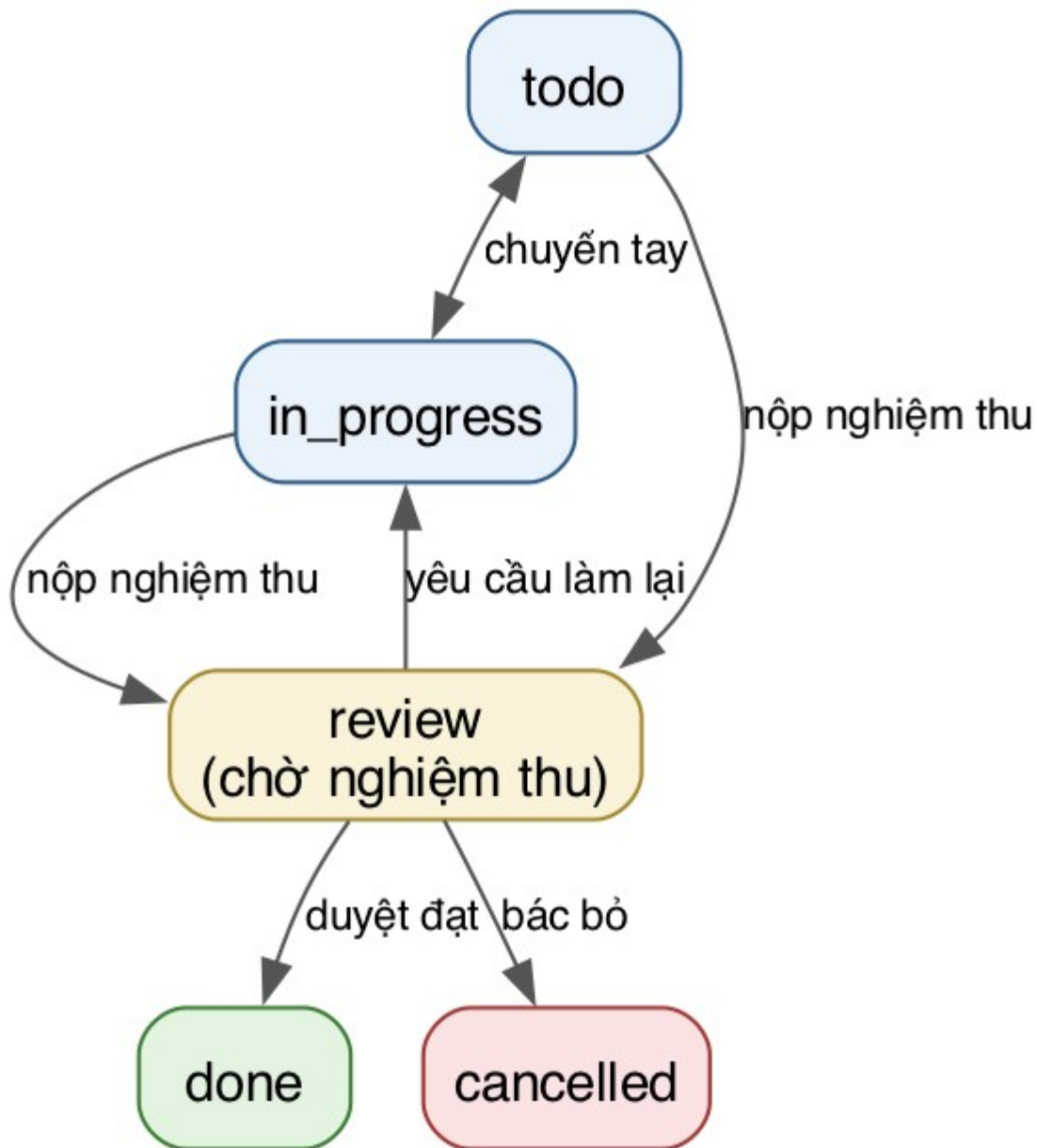
- POST /api/activities/:id/log-task — một thành viên **tự khai báo một đầu việc đã làm** (không do ai giao trước) trong 1 hoạt động đã approved/active, chọn Tổ phụ trách (phải thuộc Tổ đó, trừ Ban điều hành), tự chấm **điểm trọng số** (0–10, số nguyên), kèm minh chứng (link hoặc — hiện đang tạm khóa — tệp tải lên). Task này được tạo thẳng ở trạng thái **review** (chờ nghiệm thu) và cờ is_self_logged=1; hệ thống báo cho Tổ trưởng/phó của Tổ đó để nghiệm thu.

A.6 Quản lý Công việc (Task) trong hoạt động

A.6.1 Giao việc (tạo Task)

- POST /api/activities/:id/tasks — Manager (đang quản lý hoạt động) tạo task mới: tiêu đề, mô tả, giai đoạn (stage: before/during/after/general), mức ưu tiên, Tổ phụ trách (người tạo phải quản lý được Tổ đó), 1 người phụ trách chính (bắt buộc) + có thể thêm người phụ, hạn chót, sản phẩm bàn giao mong đợi (deliverable). Mọi người được giao phải là thành viên của Tổ phụ trách. Sinh thông báo (in-app + email) cho tất cả người được giao.

A.6.2 Vòng đời trạng thái Task (*status*)



Vòng đời trạng thái công việc

- **todo** ↔ **in_progress**: chuyển tay bởi người quản lý Tổ hoặc chính người được giao — `PATCH /api/tasks/:id/status` [tasks.js:47](#). **Không được chuyển thẳng sang review hoặc done qua API này** — phải qua bước nộp nghiệm thu.
- **Nộp nghiệm thu**: `POST /api/tasks/:id/submit-review` — chỉ người được giao (`assigned_to_me`), chỉ khi task đang `todo/in_progress`; bắt buộc đính kèm minh chứng (link hoặc tệp) + ghi chú; task chuyển sang `review`, ghi nhận `submitted_for_review_at`; báo Tổ trưởng/phó của Tổ phụ trách để nghiệm thu.

- **Nghiệm thu:** POST /api/tasks/:id/review — chỉ người có quyền canReviewTask (Ban điều hành / Tổ trưởng-phó của Tổ / Trưởng BTC hoạt động; **thành viên thường không tự nghiệm thu được**), chỉ khi task đang review. 3 quyết định:
 - o approve → done (ghi completed_at, reviewed_by, reviewed_at).
 - o reject (yêu cầu làm lại) → về in_progress, bắt buộc ghi lý do.
 - o cancel (bác bỏ) → cancelled, bắt buộc ghi lý do. Mỗi quyết định ghi 1 update loại review_note và gửi email cho toàn bộ người được giao.
- **Hủy việc:** POST /api/tasks/:id/cancel — không hủy được nếu đã done hoặc đã cancelled; người thực hiện phải là: chủ sở hữu việc tự ghi nhận (rút lại), hoặc người quản lý Tổ, hoặc Ban điều hành.
- **Sửa thông tin task** (PATCH /api/tasks/:id): chỉ người quản lý Tổ mới sửa được deadline/ngày bắt đầu/mức ưu tiên/deliverable.
- **Xác nhận nhận việc** (POST /api/tasks/:id/acknowledge): người được giao xác nhận đã biết việc (acknowledged_at) — dùng để cảnh báo nếu >24h chưa xác nhận (mục A.7).

A.6.3 Việc con (Checklist)

- Thêm/tick/xóa mục checklist trong 1 task — chỉ người được giao việc hoặc người quản lý Tổ phụ trách (canTouchTask). Việc con không có ảnh hưởng tới trạng thái chính của task (không tự động hoàn thành task khi checklist xong hết).

A.6.4 Minh chứng / Tập đính kèm (Task attachments)

- Phân loại (kind): clarification (làm rõ), evidence (minh chứng), issue (sự cố), deliverable (sản phẩm bàn giao — dùng khi nộp nghiệm thu / tự ghi nhận việc).
- Có thể là **link** (http/https) hoặc **tệp tải lên**. **Lưu ý hiện trạng: chức năng tải tệp lên đang tạm khóa ở giao diện** (ô chọn tệp bị disable, chỉ dùng được link) — xem [attachmentModal](#), [app.js:1396](#) và ghi chú “Tạm thời tắt tính năng tải tệp lên, vui lòng dùng liên kết.” Backend vẫn hỗ trợ tệp (nếu bật lại UI): giới hạn định dạng theo allowedExtensions, tổng dung lượng **50 MB / task** (chỉ tệp thật tính vào quota, link không tính) (task-attachments.js).
- Xem nội dung tệp: GET /api/task-attachments/:id/content (yêu cầu nhìn thấy hoạt động chứa task đó).

A.7 Thông báo (Notifications)

A.7.1 Thông báo trong ứng dụng

- GET /api/notifications — 20 thông báo gần nhất (chưa hết hạn) + số chưa đọc; tự dọn thông báo hết hạn (expires_at, mặc định hết hạn sau 7 ngày kể từ khi tạo).
- PATCH /api/notifications/:id/seen — đánh dấu đã xem 1 thông báo.
- POST /api/notifications/seen — đánh dấu tất cả đã xem.

A.7.2 Các sự kiện phát sinh thông báo (in-app + email + push tùy loại)

Sự kiện	Người nhận	Trigger
Hoạt động mới được đề xuất	Toàn bộ Ban điều hành	Tạo hoặc nộp lại đề án
Quyết định đề án (duyet/từ)	Người tạo hoạt động	Ban điều hành ra quyết

Sự kiện	Người nhận	Trigger
chối/yêu cầu sửa)		định
Được thêm vào hoạt động	Thành viên được thêm	POST /activities/:id/participants
Được giao task mới	Người được giao (chính + phụ)	POST /activities/:id/tasks
Có phản hồi/bình luận trên task	Người giao việc (assigned_by)	POST /activities/:id/updates CỐ task_id
Được tag trong bình luận	Người bị tag	POST /activities/:id/updates CỐ tagged_user_ids
Task được nộp nghiệm thu	Tổ trưởng/Tổ phó của Tổ phụ trách	POST /tasks/:id/submit-review, hoặc tự ghi nhận việc
Kết quả nghiệm thu	Toàn bộ người được giao task	POST /tasks/:id/review
Sắp đến hạn (còn 24h hoặc 4h)	Người được giao task chưa xong	Job định kỳ (mục A.7.3)
Task quá hạn	Người được giao task chưa xong	Job định kỳ
Thành viên chưa xác nhận nhận việc sau 24h	Người giao việc	Job định kỳ

A.7.3 Job thông báo định kỳ (deadline scheduler)

Chạy nền mỗi 15 phút (startDeadlineNotificationScheduler, [deadline-notifications.js](#)), không cần thao tác người dùng: 1. Dọn thông báo hết hạn. 2. Quét task sắp đến hạn trong 24h hoặc 4h tới (hoặc còn đúng 1 ngày) → nhắc người được giao. 3. Quét task đã quá hạn (deadline < hiện tại, chưa done/cancelled) → nhắc người được giao **mỗi ngày** cho tới khi xử lý (khóa theo ngày trong source_key để không lặp trong ngày). 4. Quét việc được giao >24h mà người nhận **chưa xác nhận** (acknowledged_at IS NULL) → nhắc người giao việc.

Mỗi thông báo dùng source_key duy nhất (UNIQUE KEY) để đảm bảo **không bị trùng lặp** dù job chạy nhiều lần.

A.8 Tài liệu dùng chung (Documents)

- GET /api/documents — tìm kiếm/ lọc theo năm áp dụng, Tổ ban hành, từ khóa; phạm vi hiển thị theo visibility:
 - o all_teams: mọi người dùng thấy.
 - o issuing_team: chỉ thành viên của Tổ ban hành thấy (Ban điều hành luôn thấy tất cả).
- POST /api/documents — đăng tài liệu mới (tên, link http/https, mô tả, năm áp dụng, Tổ ban hành, phạm vi hiển thị); Leadership chỉ đăng được cho Tổ mình thuộc về.
- PATCH /api/documents/:id — sửa tài liệu; người sửa được là Ban điều hành, người tạo, hoặc thành viên của Tổ ban hành.
- **Không có chức năng xóa tài liệu** trong API hiện tại.

A.9 Báo cáo & Lưu trữ

A.9.1 Lưu trữ hoạt động đã hoàn thành

- GET /api/archive — danh sách hoạt động trạng thái completed, tìm theo từ khóa, phạm vi theo activityScope.

A.9.2 Xuất báo cáo Excel

- GET /api/reports/export (chỉ Manager trở lên) — chọn khoảng ngày, Tổ (mặc định: mọi Tổ mình quản lý), ngôn ngữ (song ngữ Anh/Việt cho tiêu đề & giá trị enum). Xuất file .xlsx gồm 3 sheet:
 1. **Activities**: danh sách hoạt động trong khoảng thời gian, loại, trạng thái, Tổ chủ trì/tham gia, số task, số task hoàn thành, số người tham gia.
 2. **Team members**: theo từng Tổ — số task được giao/hoàn thành, số hoạt động đã xác nhận/đăng ký của từng thành viên.
 3. **Member contributions**: chi tiết từng đóng góp (hoạt động, task, trạng thái, ngày hoàn thành, vai trò tham gia) theo từng thành viên.

A.10 Trang tổng quan & việc cần làm

- GET /api/bootstrap (dùng cho **Dashboard**) — số liệu tổng hợp theo phạm vi người dùng: số hoạt động đang chạy, số task mở, số task trễ hạn, số task hoàn thành trong tháng; 5 hoạt động sắp tới; tối đa 100 task đang mở (phạm vi: của tôi nếu là member; của Tổ mình quản lý + của tôi nếu Leadership; tất cả nếu Ban điều hành); 7 cập nhật gần nhất; danh sách Tổ; cờ quyền (canCreateActivity, canCreateAccount).
- GET /api/my-tasks-today (dùng cho trang **Việc hôm nay**) — 3 nhóm: task đến hạn **hôm nay**, task đã **quá hạn** (so sánh theo *ngày lịch*, không theo mốc giờ — xem ghi chú A.11.1), task đang **chờ tôi nghiệm thu** (nếu là Tổ trưởng/phó/Trưởng BTC/Ban điều hành).
- Giao diện còn có trang **Lịch hoạt động** (#calendar), **Kanban** (#board/:id — xem task theo cột trạng thái của 1 hoạt động), **Công việc của tôi** (#my-tasks) — các trang này dùng lại dữ liệu từ các API trên, không có endpoint backend riêng.

A.11 Các quy tắc nghiệp vụ & trường hợp biên đáng chú ý

Phần này liệt kê các quyết định thiết kế/quy tắc **không hiển nhiên** — BA bắt buộc phải đưa các quy tắc này vào **luồng ngoại lệ/thay thế** của use case liên quan, và team dev cân nhắc có phải đây cũng là điểm cần cải tiến (đưa vào Đầu ra 3 nếu thấy bất hợp lý):

1. **So sánh quá hạn theo ngày lịch, không theo mốc giờ**: việc xác định “quá hạn hôm nay” dùng $\text{DATE}(\text{t.deadline}) = \text{CURDATE}()$ / $\text{t.deadline} < \text{CURDATE}()$ chứ không so timestamp đầy đủ — một task có hạn “hôm nay lúc 23:59” và task có hạn “hôm nay lúc 00:01” đều được tính là chưa quá hạn cho tới hết ngày hôm đó.
2. **Hoạt động bị hủy = xóa cứng vĩnh viễn**, kéo theo xóa toàn bộ task, minh chứng (kể cả file vật lý), người tham gia, bình luận liên quan. Không có “thùng rác” hay khôi phục.
3. **Task đã hủy bị ẩn khỏi các thống kê tổng quan & work plan** (Dashboard, bootstrap, danh sách task trong trang chi tiết hoạt động lọc `status!=‘cancelled’`) nhưng

bản ghi task vẫn còn trong CSDL (khác với activity — task cancelled không bị xóa cứng).

4. **Task không tự chuyển sang review/done qua thao tác đổi trạng thái thường** — bắt buộc phải qua hành động “nộp nghiệm thu” kèm minh chứng, rồi người có thẩm quyền nghiệm thu mới chuyển done.
5. **“Tự ghi nhận việc” (self-logged task)** đi thẳng vào trạng thái review (bỏ qua todo/in_progress) — vì bản chất việc đã được làm xong, chỉ cần Tổ trưởng xác nhận điểm trọng số & minh chứng.
6. **Tải tệp lên đang bị tắt tạm thời ở giao diện** (chỉ còn nhận link làm minh chứng) dù backend vẫn hỗ trợ tệp — đây là hạn chế tạm thời cần theo dõi để cập nhật tài liệu khi được bật lại.
7. **Xóa tài khoản/Tổ có dữ liệu liên quan sẽ tự chuyển thành vô hiệu hóa (soft-delete)** thay vì báo lỗi cứng, để tránh phá vỡ ràng buộc dữ liệu lịch sử.
8. **Vai trò hệ thống (role) của user luôn được tính lại tự động** từ vai trò trong các Tổ (is_lead/is_vice_lead) mỗi khi thành viên được thêm/gỡ/đổi vai trò trong bất kỳ Tổ nào — trừ tài khoản Ban điều hành (không bị hạ cấp tự động).
9. **Quyền nghiệm thu task không bao gồm thành viên thường**, kể cả khi họ là người được giao chính — phải là cấp Tổ trưởng/phó trở lên hoặc Trưởng BTC hoạt động.
10. **Onboarding bắt buộc cho tài khoản HUST**: giảng viên/nhân viên phải xác nhận thông báo trước khi dùng hệ thống; sinh viên phải khai lớp — chặn bằng modal không cho tắt (`dialog.addEventListener('cancel', e => e.preventDefault())`).
11. **Thông báo dùng khóa chống trùng (source_key UNIQUE)** — về mặt nghiệp vụ, một sự kiện (vd. “task X sắp đến hạn trong 24h”) chỉ tạo đúng 1 thông báo, kể cả khi job chạy nhiều lần hoặc bị trùng thời điểm.
12. **Hoạt động “công khai” (is_public)** thấy được bởi mọi người dùng đăng nhập bất kể có thuộc Tổ tham gia hay không — khác với cơ chế phân quyền theo Tổ mặc định.

A.12 Phụ lục — Danh mục endpoint theo module

Module	File
Hoạt động (Activity), Task con trong hoạt động, Tự ghi nhận việc	src/routes/activities.js
Công việc (Task) chi tiết, checklist, nộp/nghiệm thu, hủy	src/routes/tasks.js
Tài khoản người dùng	src/routes/users.js
Tổ/Ban	src/routes/teams.js
Tài liệu dùng chung	src/routes/documents.js
Thông báo	src/routes/notifications.js
Báo cáo/Lưu trữ	src/routes/reports.js
Đăng nhập/SSO/Dashboard/Cấu hình	src/routes/system.js

Quan hệ dữ liệu chính (xem đầy đủ trong [db.sql](#)): Team 1—n UserTeam n—1 User; Activity n—1 Team (chủ trì) và Activity n—n Team (qua activity_teams); Activity 1—n Task; Task n—n User (qua task_assignees); Task 1—n TaskAttachment, 1—n TaskChecklist; Activity/Task 1—n Update.

PHẦN B — BACKLOG USE CASE CẦN ĐẶC TẢ

BA chia nhau đặc tả theo từng Epic dưới đây. Mỗi dòng là 1 use case cần viết theo Đầu ra 1. Cột “Nguồn” trở tới mục Phần A và endpoint liên quan để tra cứu.

Epic 1 — Xác thực & Onboarding

UC ID	Tên Use Case	Actor chính	Nguồn
UC-01	Đăng nhập bằng tài khoản nội bộ	Mọi người dùng	A.3.1 · POST /api/login
UC-02	Đăng nhập bằng tài khoản HUST (SSO Microsoft)	Sinh viên/Giảng viên HUST	A.3.2 · GET /auth/microsoft*
UC-03	Đăng xuất	Mọi người dùng	A.3.1 · POST /api/logout
UC-04	Xác nhận thông báo dành cho giảng viên/nhân viên (lần đầu đăng nhập)	Giảng viên/nhân viên HUST	A.3.2 · POST /api/onboarding/faculty-notice
UC-05	Khai báo lớp (lần đầu đăng nhập)	Sinh viên HUST	A.3.2 · POST /api/onboarding/student-class
UC-06	Cập nhật hồ sơ cá nhân	Mọi người dùng	A.3.3 · PATCH /api/account

Epic 2 — Quản lý Tổ/Ban

UC ID	Tên Use Case	Actor chính	Nguồn
UC-07	Tạo Tổ/Ban mới	Ban điều hành	A.4 · POST /api/teams
UC-08	Sửa thông tin Tổ/Ban	Ban điều hành, Tổ trưởng/phó	A.4 · PATCH /api/teams/:id
UC-09	Xóa/Vô hiệu hóa Tổ/Ban	Ban điều hành	A.4 · DELETE /api/teams/:id
UC-10	Thêm thành viên vào Tổ	Ban điều hành, Tổ trưởng/phó	A.4 · POST /api/teams/:id/members
UC-11	Đổi vai trò thành viên trong Tổ (thăng/giáng Tổ trưởng-phó)	Ban điều hành	A.4 · PATCH /api/teams/:id/members/:userId

UC ID	Tên Use Case	Actor chính	Nguồn
UC-12	Gỡ thành viên khỏi Tổ	Ban điều hành, Tổ trưởng/phó	A.4 · DELETE /api/teams/:id/members/:userId
UC-13	Xem tổng quan khối lượng công việc của Tổ	Ban điều hành, Tổ trưởng/phó	A.4 · GET /api/teams/:id/overview

Epic 3 — Quản lý tài khoản

UC ID	Tên Use Case	Actor chính	Nguồn
UC-14	Tạo tài khoản mới	Ban điều hành, Tổ trưởng/phó	A.3.4 · POST /api/users
UC-15	Nhập hàng loạt tài khoản (bulk import)	Ban điều hành	A.3.4 · POST /api/users/bulk-import
UC-16	Sửa thông tin/vai trò tài khoản	Ban điều hành, Tổ trưởng/phó	A.3.4 · PATCH /api/users/:id
UC-17	Xóa/Vô hiệu hóa tài khoản	Ban điều hành, Tổ trưởng/phó	A.3.4 · DELETE /api/users/:id
UC-18	Xem danh sách thành viên	Mọi người dùng (phạm vi khác nhau)	A.3.4 · GET /api/people

Epic 4 — Vòng đời Hoạt động

UC ID	Tên Use Case	Actor chính	Nguồn
UC-19	Đề xuất hoạt động mới	Ban điều hành, Tổ trưởng/phó	A.5.2/A.5.3 · POST /api/activities
UC-20	Nộp / nộp lại đề án hoạt động	Người quản lý hoạt động	A.5.2 · POST /api/activities/:id/submit
UC-21	Phê duyệt đề án hoạt động	Ban điều hành	A.5.2 · POST /api/activities/:id/approve
UC-22	Từ chối đề án hoạt động (kèm xóa cứng)	Ban điều hành	A.5.2, A.11.2 · POST /api/activities/:id/reject
UC-23	Yêu cầu sửa đổi đề án	Ban điều hành	A.5.2 · POST /api/activities/:id/request-changes
UC-24	Sửa thông tin hoạt động	Người quản lý hoạt động	A.5.3 · PATCH /api/activities/:id
UC-25	Đổi trạng thái hoạt động (active/completed/c	Ban điều hành	A.5.2, A.11.2 · PATCH /api/activities/:id

UC ID	Tên Use Case	Actor chính	Nguồn
	ancelled)		
UC-26	Xóa hoạt động thủ công	Ban điều hành	A.5.2, A.11.2 · DELETE /api/activities/:id
UC-27	Xem danh sách & tìm kiếm hoạt động	Mọi người dùng (phạm vi khác nhau)	A.5, GET /api/activities
UC-28	Xem chi tiết hoạt động	Mọi người dùng (phạm vi khác nhau)	GET /api/activities/:id
UC-29	Đăng ký tham gia hoạt động (tự nguyện)	Mọi người dùng	A.5.4 · POST /api/activities/:id/volunteer
UC-30	Thêm/xác nhận người tham gia hoạt động	Người quản lý hoạt động	A.5.4 · POST /api/activities/:id/participants
UC-31	Đăng bình luận/cập nhật tiến độ, gắn thẻ (tag) người khác	Mọi người dùng có quyền xem	A.5.5 · POST /api/activities/:id/updates

Epic 5 — Vòng đời Công việc (Task)

UC ID	Tên Use Case	Actor chính	Nguồn
UC-32	Giao việc mới trong hoạt động	Người quản lý hoạt động	A.6.1 · POST /api/activities/:id/tasks
UC-33	Xác nhận đã nhận việc	Người được giao	A.6.2 · POST /api/tasks/:id/acknowledge
UC-34	Chuyển trạng thái task (todo ⇌ in_progress)	Người được giao, người quản lý Tổ	A.6.2 · PATCH /api/tasks/:id/status
UC-35	Sửa thông tin task (hạn, ưu tiên, deliverable)	Người quản lý Tổ	A.6.2 · PATCH /api/tasks/:id
UC-36	Nộp nghiệm thu công việc	Người được giao	A.6.2 · POST /api/tasks/:id/submit-review
UC-37	Nghiệm thu công việc (duyet đạt / yêu cầu làm lại / bác bỏ)	Tổ trưởng/phó, Trưởng BTC, Ban điều hành	A.6.2, A.11.9 · POST /api/tasks/:id/review
UC-38	Hủy công việc	Người quản lý Tổ,	A.6.2 · POST

UC ID	Tên Use Case	Actor chính	Nguồn
		Ban điều hành, chủ việc tự ghi nhận	/api/tasks/:id/cancel
UC-39	Tự ghi nhận công việc đã làm (kèm chấm điểm trọng số)	Thành viên	A.5.6 · POST /api/activities/:id/log-task
UC-40	Thêm/tick/xóa việc con (checklist) trong task	Người được giao, người quản lý Tổ	A.6.3 · POST/PATCH/DELETE /api/tasks/:id/checklist
UC-41	Thêm minh chứng/tệp/link vào task	Người liên quan task	A.6.4 · POST /api/tasks/:id/attachments
UC-42	Xem chi tiết công việc	Người liên quan	GET /api/tasks/:id

Epic 6 — Thông báo

UC ID	Tên Use Case	Actor chính	Nguồn
UC-43	Xem danh sách thông báo & số chưa đọc	Mọi người dùng	A.7.1 · GET /api/notifications
UC-44	Đánh dấu đã đọc 1/tất cả thông báo	Mọi người dùng	A.7.1
UC-45	Nhận nhắc việc sắp đến hạn / quá hạn / chưa xác nhận nhận việc (job hệ thống)	Hệ thống (actor phụ: người nhận)	A.7.3

Epic 7 — Tài liệu dùng chung

UC ID	Tên Use Case	Actor chính	Nguồn
UC-46	Đăng tài liệu dùng chung mới	Ban điều hành, Tổ trưởng/phó	A.8 · POST /api/documents
UC-47	Sửa tài liệu dùng chung	Người có quyền sửa	A.8 · PATCH /api/documents/:id
UC-48	Tìm kiếm/xem tài liệu theo năm, Tổ ban hành	Mọi người dùng (phạm vi khác nhau)	A.8 · GET /api/documents

Epic 8 — Báo cáo & Thống kê

UC ID	Tên Use Case	Actor chính	Nguồn
UC-49	Xem trang tổng	Mọi người dùng	A.10 · GET

UC ID	Tên Use Case	Actor chính	Nguồn
	quan (Dashboard)		/api/bootstrap
UC-50	Xem việc cần làm hôm nay/quá hạn/chờ nghiệm thu	Mọi người dùng	A.10 · GET /api/my-tasks-today
UC-51	Xuất báo cáo Excel theo khoảng thời gian & Tổ	Ban điều hành, Tổ trưởng/phó	A.9.2 · GET /api/reports/export
UC-52	Xem danh sách hoạt động đã lưu trữ (hoàn thành)	Mọi người dùng (phạm vi khác nhau)	A.9.1 · GET /api/archive

Ghi chú phân bổ đề xuất (chị Bao Anh điều chỉnh theo nhân lực thực tế):
Epic 1+3 (18 UC) · Epic 2 (7 UC) · Epic 4 (13 UC) · Epic 5 (11 UC) · Epic 6+7+8 (10 UC) — tổng **52 use case**. Có thể chia 4-5 người, mỗi người phụ trách 1-2 Epic để vừa học sâu 1 mảng vừa dễ review chéo.

PHẦN C — MẪU ĐẶC TẢ USE CASE (ví dụ đã điền đầy đủ)

Dùng làm khuôn mẫu bắt buộc theo cho tất cả use case ở Phần B.

UC-01 — Đăng nhập bằng tài khoản nội bộ

Mô tả sơ lược: Người dùng đăng nhập vào hệ thống bằng email và mật khẩu đã được cấp để truy cập các chức năng theo vai trò của mình.

Actor chính: Người dùng đã có tài khoản nội bộ (local). **Actor phụ:** Không có.

Tiền điều kiện: - Người dùng chưa đăng nhập (chưa có phiên hợp lệ). - Tài khoản đã tồn tại trong hệ thống với `auth_provider = local` và `is_active = 1`.

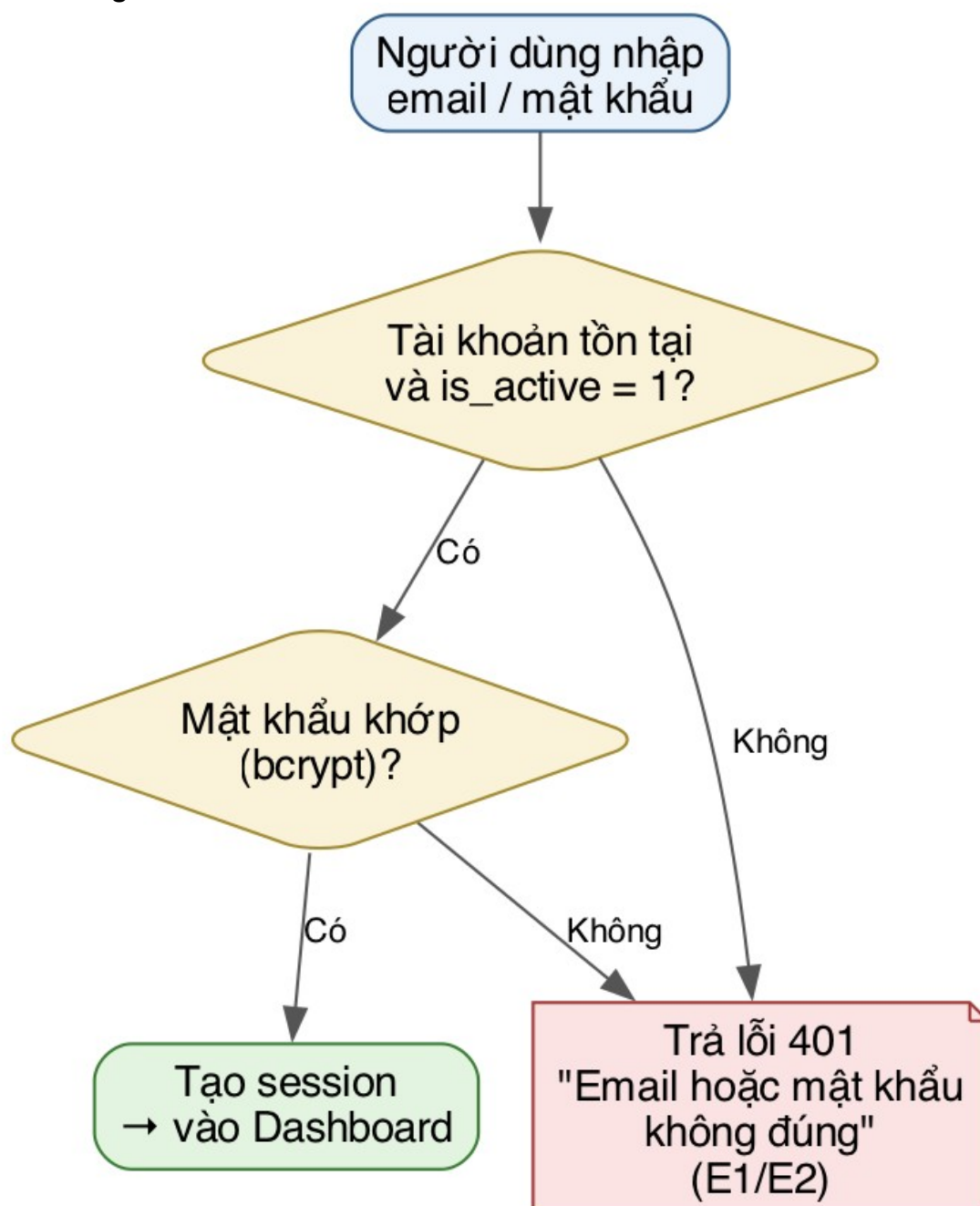
Hậu điều kiện: - *Đảm bảo tối thiểu:* Hệ thống không tạo phiên đăng nhập nếu thông tin sai; không tiết lộ tài khoản có tồn tại hay không. - *Đảm bảo thành công:* Phiên đăng nhập (session) được tạo, cookie `tckt.sid` được thiết lập (hết hạn sau 12 giờ); người dùng được chuyển tới trang Tổng quan (Dashboard) theo đúng phạm vi quyền của vai trò mình.

Luồng sự kiện chính: 1. Người dùng mở trang đăng nhập, nhập Email và Mật khẩu. 2. Người dùng nhấn nút “Đăng nhập”. 3. Hệ thống kiểm tra định dạng dữ liệu đầu vào (không rỗng). 4. Hệ thống gửi yêu cầu POST `/api/login` với email (đã chuẩn hóa chữ thường) và mật khẩu. 5. Hệ thống tra cứu tài khoản theo email với điều kiện `is_active=1`. 6. Hệ thống so khớp mật khẩu đã băm (bcrypt). 7. Hệ thống tạo phiên đăng nhập, trả về thông tin người dùng (không kèm mật khẩu). 8. Giao diện chuyển hướng người dùng vào trang Tổng quan.

Luồng sự kiện thay thế: - 5a. Nếu người dùng vừa hoàn tất luồng khai báo Onboarding bắt buộc (Faculty notice / khai lớp) ở lần đăng nhập trước nhưng chưa xác nhận, hệ thống hiển thị modal bắt buộc xác nhận trước khi cho vào Dashboard (xem UC-04, UC-05).

Luồng sự kiện ngoại lệ: - E1. Email hoặc mật khẩu không đúng, hoặc tài khoản không tồn tại → hệ thống trả lỗi chung “Email hoặc mật khẩu không đúng” (HTTP 401), không đăng nhập. - E2. Tài khoản tồn tại nhưng đã bị vô hiệu hóa (*is_active=0*) → hệ thống coi như không tìm thấy tài khoản, trả lỗi như E1 (không phân biệt để tránh dò tài khoản). - E3. Mất kết nối mạng/máy chủ trong lúc gửi yêu cầu → giao diện hiển thị thông báo lỗi kết nối, không tạo phiên, người dùng có thể thử lại. - E4. Người dùng bỏ trống email hoặc mật khẩu → giao diện chặn gửi yêu cầu, yêu cầu nhập đủ thông tin trước. - E5. Tài khoản dùng *auth_provider=microsoft* (được tạo qua SSO hoặc bulk-import) cố đăng nhập bằng mật khẩu nội bộ → do mật khẩu được cấp ngẫu nhiên không công bố, so khớp sẽ luôn thất bại → trả lỗi như E1; người dùng cần dùng luồng UC-02.

Sơ đồ luồng:



PHẦN D — MẪU BẢNG ÁNH XẠ DỮ LIỆU (ví dụ theo UC-01)

Đặt bảng này ngay dưới mỗi đặc tả use case tương ứng.

Trường trên màn hình	Kiểu dữ liệu / ràng buộc	Endpoint / method	Param trong API	Bảng & cột trong DB	Ghi chú nghiệp vụ
Email	Chuỗi, bắt	POST	email (body)	users.email	Được chuẩn

Trường trên màn hình	Kiểu dữ liệu / ràng buộc	Endpoint / method	Param trong API	Bảng & cột trong DB	Ghi chú nghiệp vụ
	buộc, định dạng email	/api/login			hóa về chữ thường trước khi so khớp; không phân biệt hoa/thường
Mật khẩu	Chuỗi, bắt buộc	POST /api/login	password (body)	users.password_hash	So khớp bằng bcrypt.compare; không lưu/trả plaintext
(ẩn) Trạng thái tài khoản	Boolean	POST /api/login	— (điều kiện WHERE)	users.is_active	Chỉ cho đăng nhập khi = 1; tài khoản bị khóa không phân biệt với “không tồn tại” ở thông báo lỗi
(ẩn) Kiểu xác thực	Enum(local, microsoft))	POST /api/login	—	users.auth_provider	Endpoint này chỉ áp dụng cho tài khoản local; tài khoản microsoft phải dùng UC-02
Phiên đăng nhập	Cookie tckt.sid	Toàn bộ API sau khi đăng nhập	Header Cookie	Bảng session (express-mysql-session, ngoài schema nghiệp vụ)	Hết hạn sau 12 giờ; httpOnly, sameSite=lax, secure khi production

Hướng dẫn điền cho các use case khác: với mỗi field nhập liệu trên UI, tra cứu đúng route xử lý trong Phần A/A.12 để lấy tên param, sau đó mở file route tương ứng trong `src/routes/` để xác nhận tên cột DB được ghi/đọc (tên cột thường trùng tên param, nhưng không phải luôn luôn — cần đối chiếu). Nếu không chắc, hỏi anh Nguyễn Trí/anh Văn Minh thay vì đoán.

PHẦN E — SHEET TỔNG HỢP ĐỀ XUẤT / KIẾN NGHỊ / BUG

Tạo 1 Google Sheet dùng chung với các cột sau (1 dòng = 1 phát hiện):

Cột	Mô tả
ID	Mã tự tăng, dạng ISS-001
Loại	Bug (sai lệch so với kỳ vọng) / Bất cập nghiệp vụ (đúng như code nhưng không hợp lý) / Đề xuất cải tiến / Thiếu tính năng
Use Case / Màn hình liên quan	Tham chiếu UC ID ở Phần B nếu có
Mô tả hiện trạng	Hệ thống đang làm gì / lỗi gì cụ thể, kèm bước tái hiện nếu là bug
Đề xuất	Người viết đề xuất nên sửa như thế nào (không bắt buộc, có thể để trống nếu chỉ nêu vấn đề)
Mức độ ảnh hưởng	Cao / Trung bình / Thấp
Người phát hiện	Tên BA
Ngày phát hiện	dd/mm/yyyy
Trạng thái xử lý	Mới / Đang xem xét / Đã lên kế hoạch / Từ chối / Đã xử lý

Một số điểm đã biết sẵn từ việc rà soát mã nguồn — BA có thể lấy làm ví dụ mẫu và bổ sung thêm khi thao tác thực tế trên UI: - Chức năng tải tệp mình chứng đang bị tắt tạm thời trên giao diện (chỉ nhận link) dù CSDL/backend vẫn hỗ trợ — cần xác nhận đây là chủ ý tạm thời hay quên bật lại. - Không có chức năng xóa tài liệu dùng chung (documents) trong khi có đủ chức năng tạo/sửa — thiếu tính đối xứng CRUD. - Hoạt động khi chuyển trạng thái “hủy” sẽ bị xóa vĩnh viễn khỏi hệ thống (không phải chỉ ẩn) — cần xác nhận đây có đúng là hành vi mong muốn về mặt nghiệp vụ (mất toàn bộ lịch sử, không thể tra cứu báo cáo hoạt động đã bị hủy).